비행제어기(FC) 시큐어코딩 적용 내역

해안정찰용 무인항공기 · 정보보호인증 기준 4.1(시큐어 코딩) | 대상: NarinFC-H7 / ArduPlane 4.6.3 (ChibiOS)

비행제어기 펌웨어는 소스코드 보안약점 7 개 유형에 대해 아래와 같이 시큐어코딩을 적용한다.

적용범위는 NarinFC-H7 용 ArduPilot 4.6.3 에 컴파일되는 직접 작성 코드만 대상으로 한다.

보안약점 유형 (KISA 기준 4.1)	비행제어기(ArduPlane/ChibiOS) 적용 내역
입력 데이터 검증 및 표현	MAVLink CRC 가 맞는 패킷만 처리. 목적지 크기를 넘는 복사는 거절하거나, 확인된 길이만 복사한다. 잔여 Cppcheck 16 건, 패턴 6 건에 대한 취약성 제거 불가 사유는 표 아래에 항목별로 별도로 정리하였다.
보안 기능	로그인 챌린지, 알 수 없는 비밀번호 해시, 솔트, 로그아웃 서명 키는 하드웨어 난수(get_true_random_vals, 제한 시간 5000µs)로 만든다. 난수 생성이 실패하면 버퍼를 0 으로 두고 실패를 반환한다. 로그인 실패 시에는 세션을 대기 상태로 두지 않고 챌린지를 보내지 않는다. 로그아웃은 새 서명 키를 만들기 전에 실패하면 기존 로그인과 서명 키를 유지한다. 이 항목의 Cppcheck·패턴 잔여는 0 건이다.
시간 및 상태	이 항목으로 분류된 Cppcheck·패턴 잔여는 0 건이다. 태스크, 워치독, 뮤텍스·세마포어 소스는 이번 조치에서 변경하지 않았다.
에러 처리	이 항목으로 분류된 Cppcheck·패턴 잔여는 0 건이다. 길이 초과와 난수 생성 실패는 반환값으로 거절하며, 그 조치는 입력 데이터 검증 및 표현과 보안 기능에 적었다.
코드 오류	결과가 같은 경고 25 건을 해소했다. 옵션 파서의 중복 검사, MS5611 의 이미 걸러진 D1 개수 검사, 이 펌웨어에서 항상 실패하는 os.tmpname 검사를 정리했다. 근접 섹터의 부호 없는 비교는 0 과 같은지로 바꿨다. 가려진 이름은

	monocypher 의 공개점과 RTCM CRC 바이트로 구분했다. PID 정보, 3×3 행렬, 2 차 저역필터는 멤버별로 0 을 넣고, 링 버퍼는 같은 객체 주소를 바이트로 캐스팅하지 않고 전달한다. readptr()이 돌려주는 주소는 링 내부 그대로다. PiccoloCAN 스케일 1.0f/1.0f 5 곳은 1.0f 로 두고, ESC 확장 경고·오류의 같은 조건 2 곳은 한 분기에서 같은 순서로 호출한다. 잔여 301 건에 대한 취약성 제거 불가 사유는 표 아래에 항목별로 별도로 정리하였다.
캡슐화	호출이나 인스턴스가 없는 21 건을 삭제했다. SCurve 의 비공개 함수 3 개(get_accel_along_track, get_accel_finished_time, braking), LSM9DS1 레지스터 덤프, MLX90614 EEPROM 읽기 래퍼, ST24 의 미사용 TelemetryData 구조체다. 비행 중 호출되는 함수와 패킷 처리 결과는 같다. 잔여 24 건에 대한 취약성 제거 불가 사유는 표 아래에 항목별로 별도로 정리하였다.
API 오용	atoi, atol, atof 33 곳은 변환이 없거나 표현 범위를 넘으면 0 을 반환하는 함수로 바꿨다. 대상은 NMEA 21 곳, Viewpro 3 곳, Xacti 4 곳, OpenDroneID 2 곳, Maxsonar 1 곳, GCS 2 곳이다. 정상 숫자와 뒤에 문자가 남은 숫자의 결과는 같다. 최신 점검에서 이 항목의 Cppcheck·패턴 잔여는 0 건이다. 남아 있는 strcpy, sscanf, popen, system 은 검사 스크립트가 입력 데이터 검증 및 표현으로 센다. 이유는 그 항목에 적었다.
보안약점 점검 (정적분석)	소스 정적분석 도구 : Cppcheck 2.7 보안약점 식별 [387]건 · 조치 [46]건 · 잔여 [341]건. 식별 387 건은 범위 복사와 숫자 변환을 반영한 뒤 Cppcheck 가 7 개 유형으로 분류한 수다. 입력 데이터 검증 및 표현 16 건, 코드 오류 326 건, 캡슐화 45 건이다. 결과가 같은 수정으로 코드 오류 25 건과 캡슐화 21 건을 해소해 조치 46 건, 잔여 341 건이다.

잔여 항목에 대한 취약성 제거 불가 사유

아래는 2026-11-04 13:54 재점검에 남은 항목이다. 같은 입력의 값, 호출 대상, 메모리 배치, 초기값을 유지할 수 있는 수정은 이미 반영했다. 남은 항목은 그 결과 중 하나가 바뀐다. 점검 대상은 ArduPlane 에 컴파일되는 직접 작성 코드 953 개(ArduPlane 64 개, libraries 889 개)다.

1. 입력 데이터 검증 및 표현 — 잔여 Cppcheck 16 건, 패턴 6 건

- **객체 인덱스(objectIndex) 16 건은** 벡터·쿼터니언·Lua 덤프가 연속 멤버를 인덱스로 읽는다. vector2.h 128·136 행과 vector3.h 141·149 행은 x, y, z 를, quaternion.h 171·180 행은 q1 부터 q4 를 읽는다. ldump.c 5 곳과 lundump.c 5 곳은 DumpVar·LoadVar 가 원소 1 개를 덤프하고 적재한다. **이 접근을 다른 복사로 바꾸면 읽기와 기록 방식이 바뀐다.** NarinFC-H7 빌드는 MATH_CHECK_INDEXES 가 꺼져 있어 인덱스 검사 코드가 들어가지 않는다. strlcpy 는 이 인덱스 경고를 없애지 못한다.
- **패턴 6 건은 비행 중 호출 경로가 없거나, 바꾸면 형식 문자열이 달라진다.** dsm.cpp:545 의 sscanf 는 TEST_HEX_STRING 호스트 테스트에서만 컴파일되고, %02x 변환 후 255 를 넘는 값은 거절한다. liolib.c:61 의 popen 은 LUA_USE_POSIX 안에 있으며 이 빌드는 그 매크로를 정의하지 않는다. loslib.c:135 의 strcpy 는 ARDUPILOT_BUILD 가 lua_tmpnam 을 먼저 바꾸므로 컴파일되지 않는다. loslib.c:156 의 system 은 os.execute 이며, luaopen_os 가 등록되지 않아 스크립트가 호출하지 못한다. lstrlib.c:1017 의 strcpy 는 string.format 이 길이 제한을 거친 짧은 수정자를 32 바이트 형식 버퍼에 넣는다. luac.c:268 의 sprintf 는 호스트 luac 가 100 바이트 버퍼에 숫자 하나를 출력하며, 비행 코드는 호출하지 않는다. Lua 소스가 검사 목록에 있어 행만 남는다.

2. 보안 기능 — 잔여 0 건

Cppcheck 와 패턴 검색이 이 항목으로 남긴 행은 없다. 인증용 난수는 하드웨어 난수로 바꿨다.

3. 시간 및 상태 — 잔여 0 건

이 항목으로 분류된 경고가 없다. ChibiOS 태스크, 워치독, 공유 자원 보호 소스는 이번 조치에서 변경하지 않았다.

4. 에러 처리 — 잔여 0 건

이 항목으로 분류된 경고가 없다. 길이 초과와 난수 생성 실패는 반환값으로 거절하고, 그 조치는 항목 1 과 항목 2 에 적었다. Failsafe 전환 로직은 이번 소스 수정 대상이 아니다.

5. 코드 오류 — 잔여 301 건

- **미초기화 멤버(uninitMemberVar) 260 건과 비공개 멤버(uninitMemberVarPrivate) 18 건을 일괄해서 0 으로 채우면 센서·필터·오토튠의 초기값이 바뀐다.** 많은 곳은 AP_Baro 110 건, Filter 49 건, AC_AutoTune 38 건, AP_Airspeed 15 건, AP_Math 13 건, AP_Proximity 10 건, AP_Compass 5 건이다.
- **복사 생성자 없음(noCopyConstructor)** 7 건과 대입 연산자 없음(noOperatorEq) 7 건은 ObjectBuffer, ObjectBuffer_TS, ObjectArray, AP_ADC_ADS1115 다. **복사와 대입을 추가하면 동적 버퍼를 나누어 갖는 방식이 바뀐다.**
- **항상 참·거짓으로 표시된 조건(knownConditionTrueFalse)** 5 건은 실제 입력에서 양쪽 결과가 가능하다. lstrlib.c:72 와 lutf8lib.c:32 는 음수 문자열 인덱스, polygon.cpp:66 의 dy1<0 은 다각형 내부 판정, vector2.cpp:348 과 372 의 t>=1 은 선분 위 최근접점이다. **분기를 지우면 문자열 위치와 기하 결과가 바뀐다.**
- **중복 대입(redundantAssignment)** 2 건은 Lua 스택을 되돌리는 대입이다. ldo.c:282 는 훅 호출 뒤 호출 프레임의 상한을 저장값으로 되돌리고, lvm.c:1081 은 문자열 연결 뒤 L->top 을 되돌린다. **앞 대입을 지우면 스택 범위가 달라진다.**
- **포인터 캐스트(invalidPointerCast)** 1 건은 ftoa_engine.cpp:93 이다. 리틀 엔디안 float 의 부호와 지수를 바이트로 읽어 숫자 문자열을 만든다. 할당 크기(sizeofCalculation) 1 건은 lstate.c:162 의 Lua 기본 스택이다. **식을 바꾸면 스택 용량이 바뀐다.**

6. 캡슐화 — 잔여 24 건

- **비공개 함수 미사용(unusedPrivateFunction)** 18 건 중 17 건은 센서 주기 콜백이다. 기압 BMP085, BMP280, BMP388, BMP581, FBM320, KellerLD, LPS2XH, SPL06, MS56XX, 대기속도 ASP5033·DLVR, 나침반 IST8308·IST8310·LSM9DS1::_update, ADS1115::_update, MAX31865::thread_tick, MLX90614::_timer 다. 소스에 직접 호출이 없어도 FUNCTOR_BIND_MEMBER 로 등록되므로, 선언을 지우면 주기 갱신이 멈춘다. functor.h 의 method_wrapper 는 bind()가 호출한다.
- **구조체 멤버 미사용(unusedStructMember)** 6 건은 lstrlib.c 의 엔디안 검사용 dummy, 정렬용 cD::c, string.pack 유니온의 d·p·i·n 이다. **멤버를 지우면 바이트 순서 판정과 팩 정렬이 바뀐다.**

7. API 오용 — 잔여 0 건

atoi, atol, atof 33 곳은 조치해 이 항목의 잔여가 0 건이다. strtok 와 alloca 패턴도 0 건이다. 남아 있는 범위 없는 복사와 외부 명령 패턴은 항목 1 의 6 건으로 센다.

7 개 유형 밖 1005 건은 인자 이름 불일치, 명시적 생성자, const 같은 스타일이다. 이번 보안약점 조치 건수에는 넣지 않았다. Copter 소스는 이번 범위 밖이다.

NarinFC-H7 보안약점 분석 결과

대상은 NarinFC-H7용 ArduPlane 펌웨어에 컴파일된 직접 작성 코드 953개입니다. 구성은 `ArduPlane/` 647개, `libraries/` 889개입니다. 부트로더, `build/` 생성물, lwIP, DroneCAN은 이 목록에 넣지 않았습니다.

사용한 명령

작업 디렉터리: `/home/jobs/ProjectGit/vololand/ArduPilot`

도구: Cppcheck 2.7 (`/usr/bin/cppcheck`)

종료 코드 0. 표준 출력은 비어 있고, 결과 XML은 표준 오류로 나왔습니다.

```
cppcheck --project=/home/jobs/ProjectGit/vololand/ArduPilot/NarinFC-H7-secure-coding-report_2026_11_03_16_44_24/compile_commands-firstparty.json \
  --enable=warning,style,portability,performance \
  --inconclusive \
  --inline-suppr \
  --suppress=missingIncludeSystem \
  --suppress=missingInclude \
  --suppress=unmatchedSuppression \
  --suppress=unusedFunction \
  --suppress=toomanyconfigs \
  -j20 \
  --quiet \
  --xml --xml-version=2 \
  > /home/jobs/ProjectGit/vololand/ArduPilot/NarinFC-H7-secure-coding-report_2026_11_03_16_44_24/cppcheck-stdout.txt \
  2> /home/jobs/ProjectGit/vololand/ArduPilot/NarinFC-H7-secure-coding-report_2026_11_03_16_44_24/cppcheck-raw.xml
```

옵션	의미
`--project=...json`	NarinFC-H7 컴파일 기록 중 직접 작성 코드 953개만 남긴 목록
`--enable=warning,style,portability,performance`	경고, 스타일, 이식성, 성능 검사. `all`은 쓰지 않음
`--inconclusive`	단정이 어려운 경고도 출력
`--inline-suppr`	소스의 cppcheck-suppress 주석을 인정
`--suppress=missingIncludeSystem`	시스템 헤더 누락 경고 제외
`--suppress=missingInclude`	프로젝트 헤더 누락 경고 제외
`--suppress=unmatchedSuppression`	맞지 않는 억제 주석 경고 제외
`--suppress=unusedFunction`	미사용 함수 검사 제외. 파일 단위 분석에서는 오탐이 큼
`--suppress=toomanyconfigs`	매크로 조합이 너무 많다는 경고 제외
`-j20`	작업 20개 동시 실행
`--quiet`	진행 문구 숨김
`--xml --xml-version=2`	결과 형식 XML 2

`--project`에 넣은 목록은 `build/NarinFC-H7/compile_commands.json`에서 `ArduPlane/`, `libraries/`만 남긴 것입니다. 같은 파일이 이 폴더의 `compile_commands-firstparty.json`입니다.

원본 파일

파일	내용
`cppcheck-raw.xml`	Cppcheck XML 원본. error 1346건
`cppcheck-stdout.txt`	표준 출력 원본. 비어 있음
`compile_commands-firstparty.json`	`--project`에 넣긴 입력
`findings-seven-categories.csv`	원본 경고와 추가 확인을 항목 번호로 나눈 전체 행

Cppcheck 원본 1346건의 심각도: style 983, warning 314, performance 46, portability 1, error 2. error 2건은 컴파일 결함이 아니라 분석기 한계입니다. `mavlink_types.h`의 `MAVPACKED` 구문, CMSIS `#error` 입니다. 이 헤더를 포함하는 파일은 분석이 멈출 수 있습니다. `ArduPlane/`에 Cppcheck 경고가 0건인 이유 중 하나입니다.

분류 규칙

Cppcheck id를 일곱 항목에 대응했습니다. 보안약점으로 보기 어려운 스타일 경고는 7항목 제외입니다. 패턴 검색과 코드 확인은 Cppcheck 원본에 없는 항목이며, CSV의 `source`가 `pattern`, `pattern-bundled`, `code-review`입니다.

Cppcheck id	항목
`objectIndex`	1. 입력 데이터 검증 및 표현 (낮음)
`duplicateCondition`	5. 코드오류 (중간)
`duplicateExpression`	5. 코드오류 (중간)
`invalidPointerCast`	5. 코드오류 (낮음)
`knownConditionTrueFalse`	5. 코드오류 (낮음)
`memsetClassFloat`	5. 코드오류 (중간)
`noCopyConstructor`	5. 코드오류 (낮음)
`noOperatorEq`	5. 코드오류 (낮음)
`redundantAssignment`	5. 코드오류 (낮음)
`redundantCondition`	5. 코드오류 (낮음)
`shadowFunction`	5. 코드오류 (낮음)
`shadowVariable`	5. 코드오류 (낮음)
`sizeofCalculation`	5. 코드오류 (중간)
`uninitMemberVar`	5. 코드오류 (낮음)
`uninitMemberVarPrivate`	5. 코드오류 (낮음)
`unsignedLessThanZero`	5. 코드오류 (낮음)
`unusedPrivateFunction`	6. 캡슐화 (낮음)
`unusedStructMember`	6. 캡슐화 (낮음)

집계

Cppcheck 건수는 경고 1건당 1회로 세었습니다. 위치가 여러 줄인 경고도 1건입니다. CSV에는 추가 위치 행이 더 있습니다.

번호	항목	Cppcheck	패턴(직접 코드)	패턴(번들)	코드 확인
1	입력 데이터 검증 및 표현	16	1	5	0
2	보안기능	0	0	0	0
3	시간 및 상태	0	0	0	0
4	에러 처리	0	0	0	0
5	코드오류	301	0	0	0
6	캡슐화	24	0	0	0
7	API 오용	0	0	0	0

Cppcheck를 항목 안에서 id로 나눈 수

항목	id	건수
1. 입력 데이터 검증 및 표현	`objectIndex`	16
5. 코드오류	`uninitMemberVar`	260
5. 코드오류	`uninitMemberVarPrivate`	18
5. 코드오류	`noCopyConstructor`	7
5. 코드오류	`noOperatorEq`	7
5. 코드오류	`knownConditionTrueFalse`	5
5. 코드오류	`redundantAssignment`	2
5. 코드오류	`invalidPointerCast`	1
5. 코드오류	`sizeofCalculation`	1
6. 캡슐화	`unusedPrivateFunction`	18
6. 캡슐화	`unusedStructMember`	6

코드 확인으로 우선 볼 항목

이 절은 Cppcheck XML에 없는 내용입니다.

이번 실행의 CSV에는 코드 확인 행이 없습니다.

항목별 패턴 위치

주석 줄은 세지 않았습니다. 번들 Lua, sagetech-sdk, monocypher는 따로 표시합니다.

1. 입력 데이터 검증 및 표현

- [pattern] libraries/AP_HAL/utility/dsm.cpp:545 scanf 계열 — if (sscanf(argv[i], "%02x", &v) != 1 || v > 255) {
- [pattern-bundled] libraries/APScripting/lua/src/liolib.c:61 외부 명령 실행 (번들 소스) — #define lpopen(L,c,m) (fflush(NULL), popen(c,m))
- [pattern-bundled] libraries/APScripting/lua/src/loslib.c:135 범위 없는 복사 (번들 소스) — strcpy(b, LUA_TMPNAMTEMPLATE); \
- [pattern-bundled] libraries/AP_Scripting/lua/src/loslib.c:156 외부 명령 실행 (번들 소스) — int stat = system(cmd);
- [pattern-bundled] libraries/AP_Scripting/lua/src/lstrlib.c:1017 범위 없는 복사 (번들 소스) — strcpy(form + l - 1, lenmod);
- [pattern-bundled] libraries/APScripting/lua/src/luoc.c:268 범위 없는 복사 (번들 소스) — sprintf(buff,LUANUMBER_FMT,ftvalue(o));

2. 보안기능

패턴 검색과 코드 확인에서 이 항목으로 넣은 추가 행은 없습니다. Cppcheck 건수는 위 집계 표를 봅니다.

3. 시간 및 상태

패턴 검색과 코드 확인에서 이 항목으로 넣은 추가 행은 없습니다. Cppcheck 건수는 위 집계 표를 봅니다.

4. 에러 처리

패턴 검색과 코드 확인에서 이 항목으로 넣은 추가 행은 없습니다. Cppcheck 건수는 위 집계 표를 봅니다.

5. 코드오류

패턴 검색과 코드 확인에서 이 항목으로 넣은 추가 행은 없습니다. Cppcheck 건수는 위 집계 표를 봅니다.

6. 캡슐화

패턴 검색과 코드 확인에서 이 항목으로 넣은 추가 행은 없습니다. Cppcheck 건수는 위 집계 표를 봅니다.

7. API 오용

패턴 검색과 코드 확인에서 이 항목으로 넣은 추가 행은 없습니다. Cppcheck 건수는 위 집계 표를 봅니다.